



امنیت داده و شبکه

نیم سال دوم ۱۴۰۴-۰۵

دکتر مهدی خرازی و دکتر مرتضی امینی

پاسخ دهنده: معین آعلی - ۴۰۱۱۰۵۵۶۱

تمرین سوم

فهرست مسائل

۱		مسئله ۱
۲		مسئله ۲
۲		رمزنگاری RSA
۳		تبادل کلید Diffie-Hellman
۵		مسئله ۳
۵		احراز هویت پیام‌های با طول مشخص توسط فرستنده
۵		محدودیت طول در سمت گیرنده
۶		مسئله ۴
۷		مسئله ۵
۸		مسئله ۶
۹		مسئله ۷

پاسخ مسئله‌ی ۱.

رابطه رمزگشایی برای بلوک i -ام به صورت زیر تعریف می‌شود:

$$P_i = D_K(C_i) \oplus C_{i-1}$$

که در آن $C_0 = IV$ است. با توجه به این رابطه، خراب شدن یک بلوک از متن رمز (C_i) تنها بر روی رمزگشایی دو بلوک از متن آشکار اثر می‌گذارد:

۱. بلوک هم‌شمار (P_i) : به دلیل حضور C_i به عنوان ورودی مستقیم تابع رمزگشایی D_K .

۲. بلوک بعدی (P_{i+1}) : به دلیل XOR شدن C_i با خروجی تابع رمزگشایی بلوک بعدی.

خطا به بلوک‌های P_{i+2} و بعد از آن منتشر نمی‌شود، زیرا C_{i+1} سالم است.

حال با فرض خراب شدن ۴ بلوک از متن رمز، دو سناریو برای حداقل و حداکثر خرابی در متن آشکار وجود دارد:

• حداکثر تعداد بلوک‌های خراب:

اگر ۴ بلوک خراب در متن رمز کاملاً غیرمتوالی و پراکنده باشند (به طوری که خطاهای آن‌ها با هم تداخل نداشته باشند)، هر بلوک خراب متن رمز، دقیقاً ۲ بلوک از متن آشکار را خراب می‌کند. در نتیجه:

$$\text{حداکثر تعداد بلوک‌های خراب} = 4 \times 2 = 8$$

• حداقل تعداد بلوک‌های خراب:

اگر ۴ بلوک خراب به صورت متوالی و پشت‌سرهم ظاهر شوند (مثلاً $(C_i, C_{i+1}, C_{i+2}, C_{i+3})$)، اثر خطای بلوک‌های قبلی روی اثر تخریبی تابع رمزگشایی بلوک‌های بعدی هم‌پوشانی پیدا می‌کند. در این حالت، بلوک‌های P_i تا P_{i+3} به خاطر ورودی نامعتبر تابع دکرپت، و بلوک P_{i+4} به خاطر XOR شدن C_{i+3} خراب می‌شوند. به طور کلی برای n بلوک متوالی خراب، $n+1$ بلوک آشکار خراب می‌شود. در نتیجه:

$$\text{حداقل تعداد بلوک‌های خراب} = 4 + 1 = 5$$

پاسخ مسئله‌ی ۲.

رمزنگاری RSA

(آ) محاسبه کلید عمومی (n, e) و کلید خصوصی (n, d) :

ابتدا مقدار n را محاسبه می‌کنیم:

$$n = p \times q = 7 \times 13 = 91$$

سپس مقدار $\phi(n)$ را به دست می‌آوریم:

$$\phi(n) = (p-1)(q-1) = (7-1)(13-1) = 6 \times 12 = 72$$

برای یافتن کلید خصوصی d ، باید معکوس ضربی $e = 7$ را به پیمانه $\phi(n) = 72$ با استفاده از الگوریتم اقلیدسی تعمیم‌یافته پیدا کنیم. یعنی حل معادله هم‌نهشتی:

$$7d \equiv 1 \pmod{72}$$

مراحل الگوریتم تقسیم اقلیدسی (رو به جلو):

$$72 = 10 \times 7 + 2$$

$$7 = 3 \times 2 + 1$$

حالا مراحل را به صورت بازگشتی (رو به عقب) برای یافتن ترکیب خطی بنویسیم:

$$1 = 7 - 3 \times 2$$

جایگذاری $2 = 72 - 10 \times 7$:

$$1 = 7 - 3 \times (72 - 10 \times 7)$$

$$1 = 7 - 3 \times 72 + 30 \times 7$$

$$1 = 31 \times 7 - 3 \times 72$$

بنابراین:

$$31 \times 7 \equiv 1 \pmod{72} \implies d = 31$$

کلید عمومی: $(n, e) = (91, 7)$

کلید خصوصی: $(n, d) = (91, 31)$

(ب) رمزگذاری پیام $M = 82$ و محاسبه متن رمز نشده C :

فرمول رمزگذاری:

$$C \equiv M^e \pmod{n} \implies C \equiv 82^7 \pmod{91}$$

ابتدا پایه را ساده می‌کنیم: $82 \equiv -9 \pmod{91}$. پس:

$$C \equiv (-9)^7 \pmod{91}$$

$$(-9)^2 = 81 \equiv -10 \pmod{91}$$

$$(-9)^4 \equiv (-10)^2 = 100 \equiv 9 \pmod{91}$$

$$(-9)^6 = (-9)^4 \times (-9)^2 \equiv 9 \times (-10) = -90 \equiv 1 \pmod{91}$$

در نهایت:

$$C \equiv (-9)^7 = (-9)^6 \times (-9)^1 \equiv 1 \times (-9) = -9 \equiv 82 \pmod{91}$$

پس متن رمزگذاری شده برابر است با: $C = 82$

ج) رمزگشایی متن C و بازگشت به پیام اصلی M :

فرمول رمزگشایی:

$$M = C^d \pmod{n} \implies M = 82^{31} \pmod{91}$$

با توجه به این که $82 \equiv -9 \pmod{91}$ ، داریم:

$$M \equiv (-9)^{31} \pmod{91}$$

با استفاده از محاسبات بخش قبل می‌دانیم که $(-9)^6 \equiv 1 \pmod{91}$. بنابراین توان را به پیمانه ۶ ساده می‌کنیم:

$$31 = 5 \times 6 + 1$$

$$(-9)^{31} = ((-9)^6)^5 \times (-9)^1 \equiv (1)^5 \times (-9) = -9 \equiv 82 \pmod{91}$$

پس پیام رمزگشایی شده برابر با $M = 82$ است که با پیام اولیه کاملاً مطابقت دارد.

تبادل کلید Diffie-Hellman

آ) یافتن کلید خصوصی آلیس (X_A) در صورت داشتن کلید عمومی $Y_A = 9$:

فرمول کلید عمومی در پروتکل دیفی-هلمن عبارت است از:

$$Y_A = \alpha^{X_A} \pmod{q} \implies 9 = 2^{X_A} \pmod{11}$$

با آزمون مقادیر مختلف برای X_A (از ۱ تا ۱۰):

$$2^1 = 2 \pmod{11} \bullet$$

$$2^2 = 4 \pmod{11} \bullet$$

$$2^3 = 8 \pmod{11} \bullet$$

$$2^4 = 16 \equiv 5 \pmod{11} \bullet$$

$$2^5 = 32 \equiv 10 \pmod{11} \bullet$$

$$2^6 = 64 \equiv 9 \pmod{11} \bullet$$

بنابراین، کلید خصوصی آلیس برابر است با: $X_A = 6$

مسئله پیدا کردن X_A از روی Y_A ، α و q به نام مسئله لگاریتم گسسته شناخته می‌شود. برای اعداد اول بسیار بزرگ (q با چند صد رقم)، هیچ الگوریتم کلاسیک با زمان چندجمله‌ای برای حل این مسئله در زمان معقول وجود ندارد و امنیت این پروتکل نیز دقیقاً بر پایه همین دشواری استوار است.

ب) محاسبه کلید مشترک K_{AB} در صورت داشتن کلید عمومی باب $Y_B = 3$:

هر دو طرف می‌توانند به طور مستقل کلید مشترک را محاسبه کنند:

۱. محاسبه توسط آلیس (با استفاده از کلید عمومی باب Y_B و کلید خصوصی خود $X_A = 6$):

$$K_{AB} = Y_B^{X_A} \pmod{q} = 3^6 \pmod{11}$$

$$3^2 = 9 \equiv -2 \pmod{11}$$

$$3^4 \equiv (-2)^2 = 4 \pmod{11}$$

$$3^6 = 3^4 \times 3^2 \equiv 4 \times 9 = 36 \equiv 3 \pmod{11}$$

بنابراین کلید مشترک از نظر آلیس ۳ است.

۲. محاسبه توسط باب (ابتدا نیاز به یافتن کلید خصوصی خود X_B دارد):

$$Y_B = \alpha^{X_B} \pmod{q} \implies 3 = 2^{X_B} \pmod{11}$$

با ادامه بررسی توان‌های ۲ از بخش قبل:

$$2^7 = 2^6 \times 2 \equiv 9 \times 2 = 18 \equiv 7 \pmod{11} \bullet$$

$$2^8 = 2^7 \times 2 \equiv 7 \times 2 = 14 \equiv 3 \pmod{11} \bullet$$

پس کلید خصوصی باب $X_B = 8$ است. حالا باب کلید مشترک را با کلید عمومی آلیس ($Y_A = 9$) محاسبه می‌کند:

$$K_{AB} = Y_A^{X_B} \pmod{q} = 9^8 \pmod{11}$$

$$\text{از آنجا که } 9 \equiv -2 \pmod{11}:$$

$$9^8 \equiv (-2)^8 = 256 \pmod{11}$$

$$\text{با تقسیم } 256 \text{ بر } 11 \text{ داریم: } 256 = 23 \times 11 + 3 \text{ پس } 256 \equiv 3 \pmod{11}.$$

مشاهده می‌شود که هر دو طرف به طور مستقل به کلید مشترک یکسان $K_{AB} = 3$ رسیدند.

پاسخ مسئله‌ی ۳.

احراز هویت پیام‌های با طول مشخص توسط فرستنده

فرض کنید فرستنده فقط برای پیام‌های دو بلوکی تگ تولید می‌کند و گیرنده طول پیام را بررسی نمی‌کند. مهاجم برای جعل پیام چهاربلوکی $M = (m_1, m_2, m_3, m_4)$ به صورت زیر عمل می‌کند:

۱. پیام $M_1 = (m_1, m_2)$ را به فرستنده می‌دهد و تگ $t_1 = E_k(m_2 \oplus E_k(m_1))$ را دریافت می‌کند.

۲. سپس پیام $M_2 = (m_3 \oplus t_1, m_4)$ را به فرستنده می‌دهد و تگ $t_2 = E_k(m_4 \oplus E_k(m_3 \oplus t_1))$ را دریافت می‌کند.

۳. مهاجم ادعا می‌کند که t_2 تگ معتبر پیام $M = (m_1, m_2, m_3, m_4)$ است.

گیرنده برای محاسبه CBC-MAC پیام M خواهد داشت:

$$c_1 = E_k(m_1)$$

$$c_2 = E_k(m_2 \oplus c_1) = E_k(m_2 \oplus E_k(m_1)) = t_1$$

$$c_3 = E_k(m_3 \oplus c_2) = E_k(m_3 \oplus t_1)$$

$$c_4 = E_k(m_4 \oplus c_3) = E_k(m_4 \oplus E_k(m_3 \oplus t_1)) = t_2$$

بنابراین $CBCMAC(M) = t_2$ و گیرنده تگ را معتبر می‌پذیرد. پس CBC-MAC در صورت عدم کنترل طول پیام در برابر این جعل آسیب‌پذیر است.

محدودیت طول در سمت گیرنده

فرض کنید گیرنده فقط پیام‌های سه‌بلوکی را می‌پذیرد، اما فرستنده برای هر طولی تگ تولید می‌کند.

۱. مهاجم پیام $M_1 = (m_1, m_2)$ را ارسال کرده و تگ $t_1 = E_k(m_2 \oplus E_k(m_1))$ را دریافت می‌کند.

۲. سپس پیام تک‌بلوکی $M_2 = (m_3)$ را ارسال کرده و تگ $t_2 = E_k(m_3)$ را دریافت می‌کند.

۳. اکنون پیام $M^* = (m_1, m_2, m_3 \oplus t_1)$ را همراه با تگ t_2 برای گیرنده می‌فرستد.

گیرنده محاسبه می‌کند:

$$c_1 = E_k(m_1),$$

$$c_2 = E_k(m_2 \oplus c_1) = t_1,$$

$$c_3 = E_k((m_3 \oplus t_1) \oplus c_2) = E_k((m_3 \oplus t_1) \oplus t_1) = E_k(m_3) = t_2.$$

در نتیجه $CBCMAC(M^*) = t_2$ و گیرنده تگ را معتبر می‌پذیرد. بنابراین صرف محدود کردن طول پیام در سمت گیرنده نیز امنیت CBC-MAC را تضمین نمی‌کند.

پاسخ مسئله‌ی ۴.

پاسخ مسئله‌ی ۵.

پاسخ مسئله‌ی ۶.

پاسخ مسئله‌ی ۷.